

מודול 16 — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 16: כתיבת דוח ותיעוד

2.  פתרונות ודוגמאות — מודול 16: כתיבת דוח ותיעוד

תרגילים — מודול 16: כתיבת דוח ותיעוד

תרגילים אלה מתמקדים ב**כתיבה** — קח ממצאים מהמודולים הקודמים והפוך אותם לדוח מקצועי. פתרונות ודוגמאות ב- `solutions.md`.

לפני שמתחילים — קרא אותי!

- **מה צריך:** עורך טקסט (Word / Markdown / Google Docs) והממצאים מהמודולים הקודמים (במיוחד האתגרים של מודול 9/11/13). **אין צורך במכונת יעד** — זה מודול כתיבה.
- **איך עובדים:** קרא קודם את ה- `README.md` — יש בו מבנה דוח וממצא לדוגמה. לכל תרגיל יש  **רמז** לסעיף המתאים ו- **קריטריון**.
- **נתקעת?** ב- `solutions.md` יש **דוגמאות כתובות** לכל תרגיל (Executive Summary, ממצא מלא, טבלה) — העתק את המבנה והתאם לממצאים שלך.
- **טיפ:** דוח טוב = חצי מהעבודה של בודק חדירות. זה מה שהלקוח באמת מקבל.

איפה לתרגל — שתי דרכים

- **TryHackMe**  (בדפדפן, ללא התקנה):  אין חדר ייעודי — כתיבת דוח היא משימת **כתיבה**, לא פריצה.
- **Kali (מקומי):**  כל עורך (Word/Markdown/**Sysreptor**/CherryTree); כתוב דוח על בסיס בדיקה שביצעת (תבניות SANS/TCM).

מקרא רמות:  קל ·  בינוני ·  מתקדם ·  אתגר

האתגר הגדול — הדוח שמשיג לך עבודה

קח פריצה אמיתית שביצעת בקורס (מודול 7/9/13) והפוך אותה ל**דוח מקצועי** שחברה הייתה משלמת עליו — עם Executive Summary, דירוג CVSS, PoC והמלצות תיקון.

🏆 **אתגר עמיתים (Peer Review):** החלף דוחות עם חבר, ודרגו זה את זה לפי בהירות ומקצועיות.  הצלחה: יש לך דוח בדיקת חדירה אמיתי לתיק העבודות — בדיוק מה שמציגים בראיון עבודה.

חלק א' — יסודות (🟢)

16.1 — הסבר במילים שלך למה "הדוח הוא המוצר". מה קורה לבדיקה מבריקה עם דוח גרוע? 💡 רמז: README §16.1.  הצלחה: הסברת שהלקוח רואה רק את הדוח; דוח גרוע = הלקוח לא מבין ולא מתקן.

16.2 — מהם Scope ו-RoE, ולמה חובה להגדירם בכתב לפני הבדיקה? 💡 רמז: README §16.2.  הצלחה: Scope=מה מותר, RoE=איך/מתי; בלעדיהם חשיפה משפטית.

16.3 — רשום את ששת חלקי הדוח הסטנדרטי לפי הסדר. 💡 רמז: README §16.3 (הטבלה).  הצלחה: שער → Executive Summary → מתודולוגיה → סיכום → ממצאים → נספחים.

חלק ב' — כתיבה (🟡)

16.4 — כתוב Executive Summary לתרחיש: SQLi בדף לקוחות שחושף את כל מסד הנתונים. שפה עסקית, ללא זירגון. 💡 רמז: README §16.4 (דוגמת /). דבר על סיכון עסקי, לא על טכניקה.  הצלחה: פסקה שמנהל לא-טכני מבין, שמדגישה סיכון (חשיפת מידע, קנס, מוניטין).

16.5 — קח ממצא ממודול קודם (IDOR / Kerberoast) וכתוב אותו במבנה ממצא מלא. 💡 רמז: README §16.5 (מבנה הממצא). כלול: תיאור, השפעה, PoC, תיקון, הפניות.  הצלחה: ממצא שלם עם כל 5 המרכיבים.

16.6 — דרג שלושה ממצאים ב-CVSS ונמק: (א) SQLi בדף לקוחות ציבורי; (ב) banner שחושף גרסה; (ג) סיסמת admin חלשה. 💡 רמז: README §16.6 (טבלת החומרה).  הצלחה: (א) Critical, (ב) High, Low/Info — עם נימוק לכל אחד.

חלק ג' — מקצועיות (🟠)

16.7 — כתוב המלצות תיקון לשלושת הממצאים מ-16.6 — ספציפיות, ישימות, מדורגות. 💡 רמז: README §16.7 (טבלת התיקונים).  הצלחה: תיקון קונקרטי לכל ממצא, מדורג לפי עדיפות.

16.8 — הסבר איך תתעד ממצא בזמן אמת. אילו כלים, ולמה לא לחכות לסוף? 💡 רמז: README §16.8.  הצלחה: הזכרת צילומי מסך + לוג פקודות + מחברת; והסברת שפרטים נשכחים.

16.9 🟡 — נסח **טבלת סיכום ממצאים** (Finding | Severity | Status) ל-5 ממצאים לדוגמה. 💡 רמז: solutions.md — יש שם דוגמה מוכנה. ✅ הצלחה: טבלה עם 5 שורות מדורגות לפי חומרה.

אתגר מסכם — “דוח בדיקת חדירה מלא”

הרכב **דוח שלם** על בסיס אחד מהאתגרים שביצעת (מודול 9 AD / 13 privesc / 11 web):

1. **שער** — לקוח (פיקטיבי), תאריכים, סיווג.
2. **Executive Summary** — תמונת מצב + סיכון עסקי + 3 המלצות מפתח.
3. **היקף ומתודולוגיה** — מה נבדק ואיך.
4. **טבלת סיכום ממצאים** — כל הממצאים + חומרה.
5. **מצאים מפורטים** — לפחות 3 **מצאים** במבנה מלא (עם PoC וצילומים).
6. **נספח** — פלטים/פקודות.

💡 רמז: שלד דוח מלא ב- solutions.md. השתמש בממצאים אמיתיים שתיעדת בקורס. ✅ הצלחה: דוח שלם עם 6 החלקים, +3 ממצאים, שאפשר להראות בראיון עבודה.

👉 זהו **תוצר הגמר של הקורס** — דוח בדיקת חדירה אמיתי. שמור אותו כפורטפוליו.

✅ רשימת בקרה — סיום הקורס

- ☐ אני מבין שהדוח הוא המוצר ומקדיש לו זמן
- ☐ אני מגדיר Scope/RoE לפני בדיקה
- ☐ אני כותב Executive Summary בשפה עסקית
- ☐ אני כותב ממצא מלא עם PoC ותיקון
- ☐ אני מדרג חומרה עם CVSS לפי סיכון עסקי
- ☐ אני כותב המלצות תיקון ספציפיות וישימות
- ☐ אני מתעד בזמן אמת עם כלים מתאימים
- ☐ הרכבתי דוח בדיקת חדירה מלא לפורטפוליו

פתרונות ודוגמאות: solutions.md

פתרונות ודוגמאות — מודול 16: כתיבת דוח ותיעוד

חלק א' — יסודות

16.1 — הלקוח לא רואה את הפריצה, רק את הדוח; הדוח מתרגם ממצאים לערך (סיכון, תיקון, ציות). בדיקה מבריקה עם דוח גרוע = הלקוח לא מבין ולא מתקן → כישלון מקצועי.

16.2 — **Scope** = מה מותר לבדוק (טווחי IP, דומיינים, אפליקציות); **RoE** = איך ומתי (חלונות זמן, מגבלות, אנשי קשר). חובה בכתב מראש כי בלעדיהם אתה **חשוף משפטי** ועלול לפגוע במערכות מחוץ להיקף.

16.3 — (1 שער ופרטים; 2 Executive Summary; 3 היקף ומתודולוגיה; 4 סיכום ממצאים; 5 ממצאים מפורטים; 6 נספחים).

חלק ב' — כתיבה

16.4 (דוגמה) < במהלך הבדיקה זוהתה חולשה קריטית באתר הלקוחות המאפשרת לתוקף בלתי-מורשה לגשת לכל **מסד נתוני הלקוחות**, כולל שמות, כתובות ופרטי אשראי. ניצול החולשה אינו דורש הרשאות מוקדמות. הסיכון כולל **חשיפת מידע רגיש, קנסות רגולטוריים (GDPR/PCI) ופגיעה במוניטין**. מומלץ לתקן באופן מיידי.

16.5 (דוגמה — IDOR)

High (CVSS 7.5) :חומרה — (IDOR) גישה לא-מורשית לחשבונות לקוחות ##

id ניתן לשנות את הפרמטר /account?id=1001 תיאור: ** בכתובת: **
ולגשת לנתוני לקוחות אחרים ללא בדיקת בעלות.

השפעה: ** תוקף מאומת יכול לצפות בנתונים אישיים של כל הלקוחות: **
(דליפת מידע המונית).

****PoC:****

1. (החשבון שלך) /account?id=1001 -התחבר כמשתמש רגיל, גש ל.
2. מוצגים נתוני לקוח אחר. [צילום] → /account?id=1002 -שנה ל.

תיקון: ** אכוף בדיקת הרשאה בצד השרת — ודא שהמשתמש שייך: **
למשתמש המחובר בכל בקשה.

OWASP A01:2021, CWE-639. הפניות: **

16.6 - (א) SQLi בדף לקוחות ציבורי → **Critical (9.8)** — נגיש מרחוק, ללא אימות, חשיפת נתונים מלאה. -
(ב) Banner חושף גרסה → **Low/Info (3.1)** — מידע בלבד, לא ניצול ישיר. - (ג) סיסמת admin חלשה →
High (8.1) — מובילה להשתלטות, אך דורשת הגעה לממשק.

חלק ג' — מקצועיות

16.7 - **SQLi (Critical)**: תקן מיד — עבור ל-Prepared Statements/ORB בכל השאילתות; WAF כאמצעי ביניים. - **סיסמת (High) admin**: אכוף מדיניות סיסמאות חזקה + **MFA**; החלף סיסמאות קיימות. - **Banner (Low)**: הסתר גרסאות ב-headers; עדיפות נמוכה, לטיפול בתחזוקה שוטפת.

16.8 — מתעדים בזמן אמת: צילום מסך לכל ממצא (Flameshot), לוג פקודות (tmux/ script), ומחברת (CherryTree/Obsidian). לא מחכים לסוף כי הפרטים נשכחים, סביבות משתנות, ואי אפשר לשחזר PoC ממכונה שאופסה.

16.9 (דוגמה)

#	סטטוס	חומרה	ממצא
1	פתוח	Critical	בדף התחברות SQL Injection
2	פתוח	High	Kerberoastable service account
3	פתוח	High	בפרופיל לקוח IDOR
4	פתוח	Medium	סיסמאות חלשות (3 חשבונות)
5	פתוח	Low	banner-חשופה ב Apache גרסת

[CONFIDENTIAL] >דוח בדיקת חדירה - >לקוח #

___ :תאריכים: ___ | גרסה: 1.0 | בודק

1. Executive Summary

המאפשר השתלטות מלאה SQLi :החמור. (קריטיים X) ממצאים N נמצאו.
על מסד הלקוחות. סיכון עסקי: חשיפת מידע + קנס רגולטורי.
הדרכות (3) MFA; מיד; (2) אכופי SQLi המלצות מפתח: (1) תקן 3

2. היקף ומתודולוגיה

___ :חלון. PTES/OWASP :שיטה. app.client.com :נבדק

3. סיכום ממצאים

[טבלה - ראה 16.9]

4. ממצאים מפורטים

[ממצאים במבנה מלא - ראה 16.5 +3]

5. נספחים

.פקודות, רשימת מכונות, nmap פלטי

השלמת דוח מלא = סיימת את הקורס עם תוצר אמיתי לפורטפוליו. זה בדיוק מה שמגישים בבחינת

.PNPT